

MANIFOLD

A mathematical engine for mapping vulnerabilities

MANIFOLD Project

Typed IR · geometry · topology · formal verification

2026

The problem: prioritize, don't detect

- Classic SAST enumerates *patterns*: the real bottleneck is not *detecting* sinks but *deciding which one to verify*.
- On OWASP Benchmark 1.2 the Youden index $J = \text{TPR} - \text{FPR}$ collapses: SonarQube $J \approx +0.01$, CodeQL $J \approx +0.22$.
- **Question:** can a scalar field $V(x)$ over the program graph prioritize the vulnerable sink?

Main experiment: the prioritization oracle

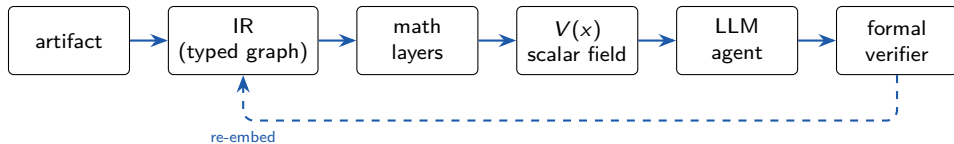
Ranking (902 vulnerable cases)	MRR	R@1	NDCG@5
DFS (source order)	0.848	0.755	0.882
raw taint	0.894	0.847	0.916
fused $V(x)$	0.872	0.805	0.899
random	0.709 ± 0.042	0.531	0.778

Per-signal AUC (does it predict the vulnerable sink?): taint 0.895 ∩ formal 0.878 ∩ spectral 0.496 ∩ topological 0.500 ∩ geometric **0.376**.

The honest result

- $V(x)$ does **not** beat raw taint: it is slightly worse (0.872 vs. 0.894).
- Spectral/topological: *indistinguishable from chance*; curvature: *worse than chance*.
- **Publishable (negative) finding:** on OWASP Benchmark the geometric and topological priors *do not survive beyond taint*.
- $\Rightarrow$ MANIFOLD's value is in the *formal* layer (verification), not the geometric prior.
L1/L2/L5: *not supported*.

The core idea



- A vulnerability is *not* a pattern: it is the *violation of a structural invariant*.

The unified IR

Program graph $G = (V, E, \tau_V, \tau_E, \omega)$:

- **Nodes**: module, function, statement, source, sink, gate, ...
- **Typed edges**: control, data, call, taint, trust, auth
- JSON shared Python $\leftrightarrow$ Rust; artifact-agnostic.

Multi-domain: the *same* IR is produced from

- Python / Java (tree-sitter), binaries (objdump or angr/CFGFast),
- OpenAPI (API surface), LLM agents (tool/trust graph).

Mathematical layers

Spectral ($L = D - A$)

λ_2 , Fiedler vector, embedding. **Topological**

(TDA)

persistent homology H_0, H_1 , Mapper.

Geometric

Ollivier–Ricci / Forman–Ricci; Sinkhorn.

Algebraic

taint lattice; authorization order. **Formal**

symbolic execution + SMT (Z3); reachability.

Directed

Chung Laplacian (SCC + Perron).

$$V(x) = \sigma(\sum_i \alpha_i s_i(x)) \quad (\text{calibrable weights } \alpha_i)$$

Mapping hypotheses (feature $\rightarrow$ vulnerability)

#	Mathematical feature	Class
H1	curvature $\kappa \ll 0$ (chokepoint)	privilege escalation
H2	persistent H_1 generator	reentrancy / recursion
H3	Fiedler cut	injection across trust
H4	taint crossing an auth edge	auth-invariant violation
H5	persistence outlier	real vs. spurious feature
H6	$\text{SAT}(\phi_{\text{bad}})$	model witness (encoded semantics)

These are *falsifiable hypotheses*, not laws; H1/H2/H5 are *not supported* on the evaluated corpora (see results).

The neuro-symbolic agent

- 1 **Map**: IR + signals $V(x)$, persistence, curvature.
- 2 **Hypothesize**: the LLM proposes over prioritized regions.
- 3 **Verify**: Z3 / taint / topology proves or refutes.
- 4 **Refine** and **report** (concrete witness).

Division of labor: mathematics proposes *regions*; the LLM proposes *hypotheses*; the solver proposes *proofs*.

Verification grammar: structured spec (sink, source, line, category) — the LLM never emits SMT-LIB.

Results: OWASP Benchmark 1.2

Tool	TPR	FPR	Prec.	F1	J	Time
SonarQube ^(a)	0.956	0.946	0.330	0.490	+0.010	~3 min
CodeQL ^(a)	0.902	0.682	0.603	0.744	+0.220	~18 min
MANIFOLD adapter ^(b)	0.842	0.674	0.572	0.681	+0.168	~45 s
MANIFOLD adapter + Z3 ^(b)	0.834	0.776	0.549	0.662	+0.057	~4 min

(a) reported in public evaluations; may use different aggregation schemes — *not* a head-to-head comparison until re-executed under a uniform protocol. (b) **measured** (Z3 adds witnesses, not precision).

Ablation: where the gain comes from

Variant (taint categories)	Prec.	Recall	F1
Initial naive adapter	0.515	0.426	0.466
+ branch-join, receiver/state taint, sink coverage	0.530	0.856	0.655
+ XSS response-writer restriction (final)	0.549	0.834	0.662
final, without branch-join	0.515	0.555	0.535

- **Branch-join** (lattice join) is the *recall* lever (+0.28).
- The **HTTP response-writer restriction** is the *precision* lever.
- Residual errors are *not* recovered by *V* or *Z3*: the field worsens the mean ranking and the *Z3* verifier reproduces the adapter's metrics. The binding limits are structural (interprocedural) and framework-internal.

- **Manifold map:** IR graph with a force-directed layout; nodes by kind, edges by kind (red taint), purple gate.
- **Findings panel:** *confirmed* (Z3 with witness) vs *candidate*.
- **Self-contained HTML** (no dependencies) + end-to-end demo on 10 artifacts.

```
python -m manifold.cli target -agent -viz out.html
```

Conclusions and future work

Conclusions

- A typed IR fuses independent signals into a navigable field $V(x)$.
- The neuro-symbolic split (math/LLM/SMT) is the right one: the LLM adds interpretability, not detection.
- **Main result (negative):** semantic dataflow dominates. The structural field helps only at very small budgets ($P@10$) and hurts on average (MRR 0.872 vs. 0.894; AP 0.434 vs. 0.489).
- Data-driven engineering works: interprocedural taint raised Juliet recall 0.562 $\rightarrow$ 0.750; framework summaries capture app-level flows.

Future work

- Uniform re-execution of CodeQL/SonarQube (methodological caveat).
- Larger CVE study; interprocedural/library-aware corpus.
- Larger LLM ablation over OWASP (ranking/interpretation/reporting).

Thank you

Map the program as a space — then test whether structure actually helps.

When geometry fails, the failure is information too.